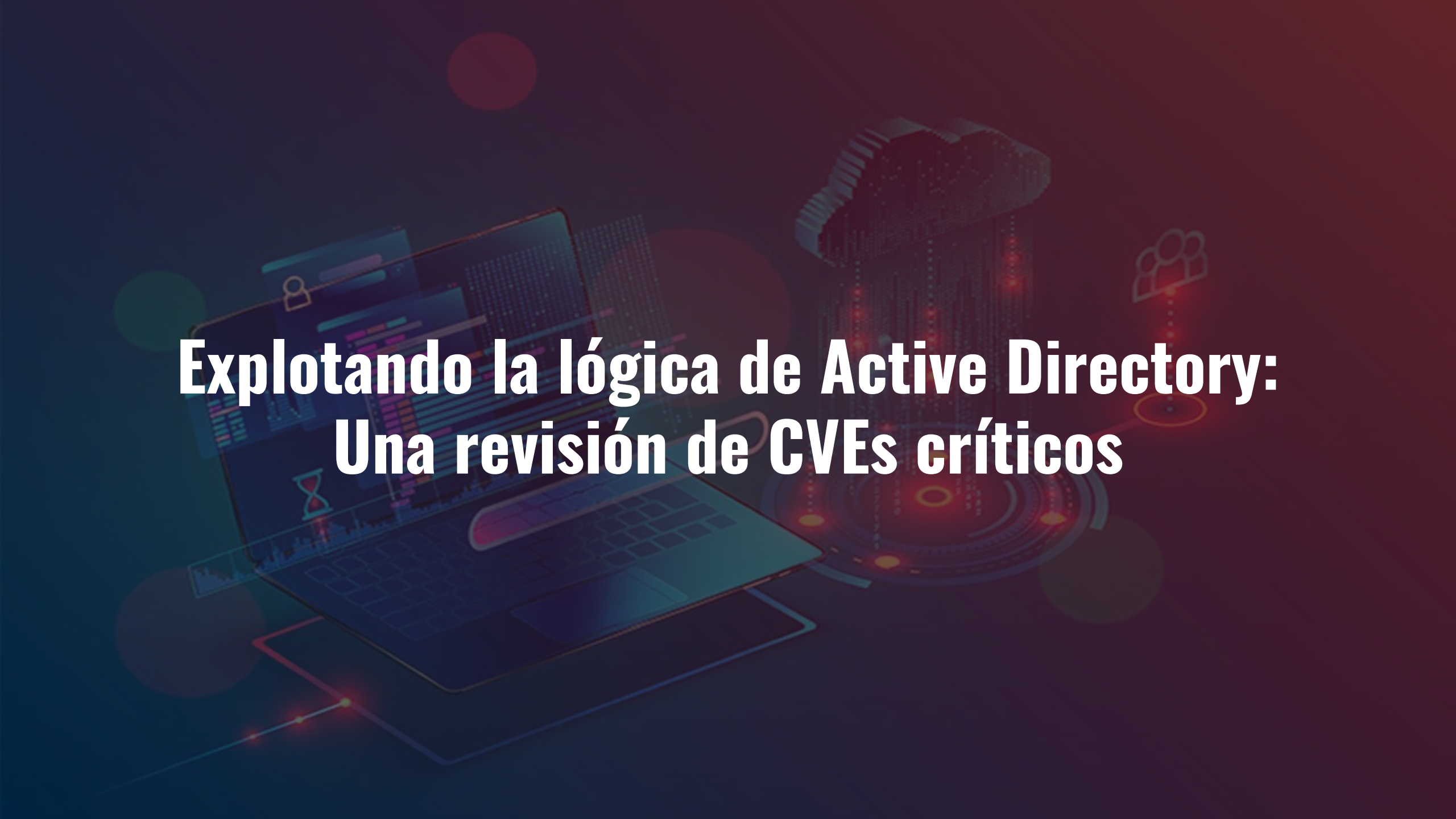


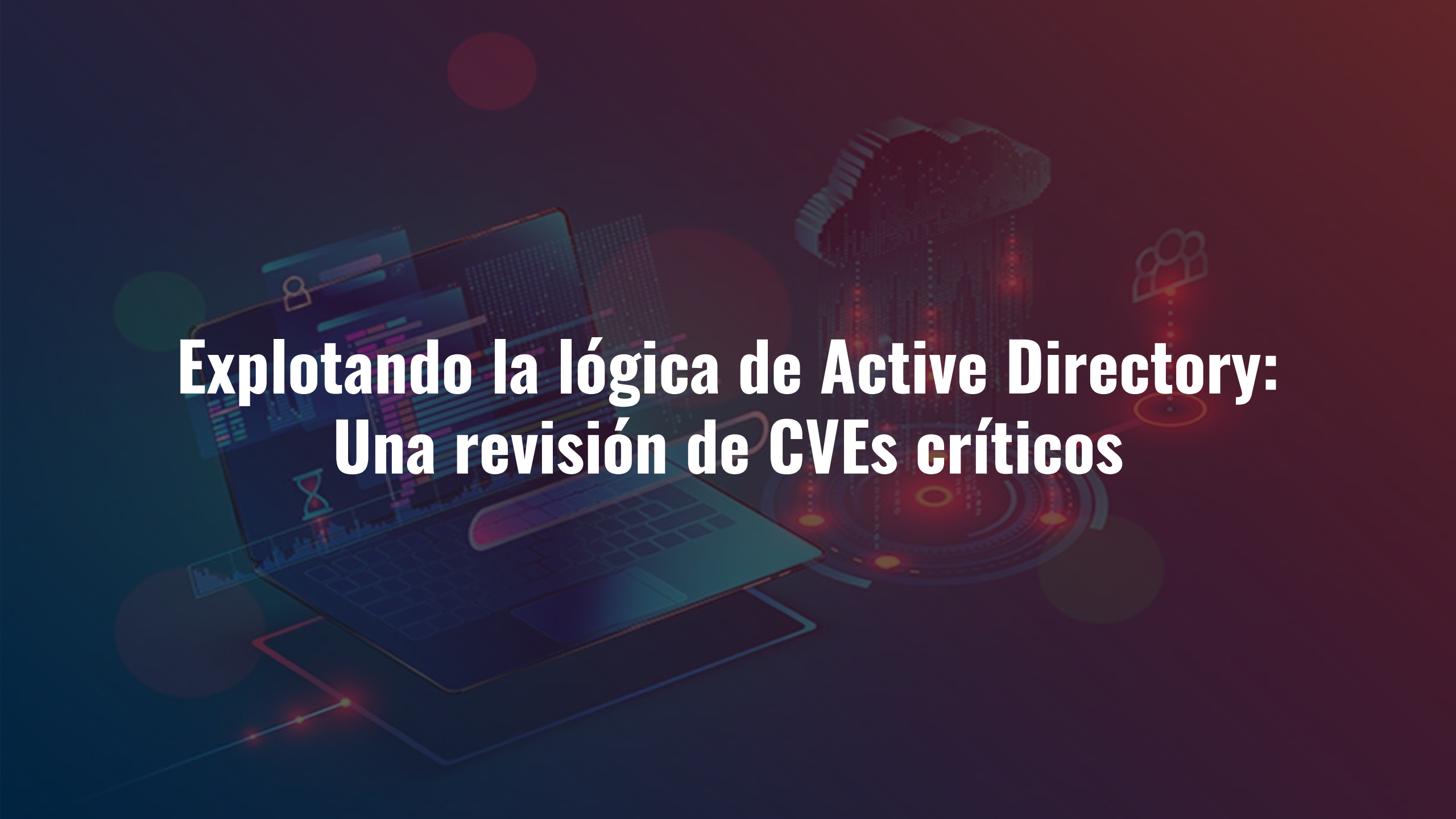
Explotando la lógica de Active Directory: Una revisión de CVEs críticos

Hugo Rivas Galindo

Layer 8 Security

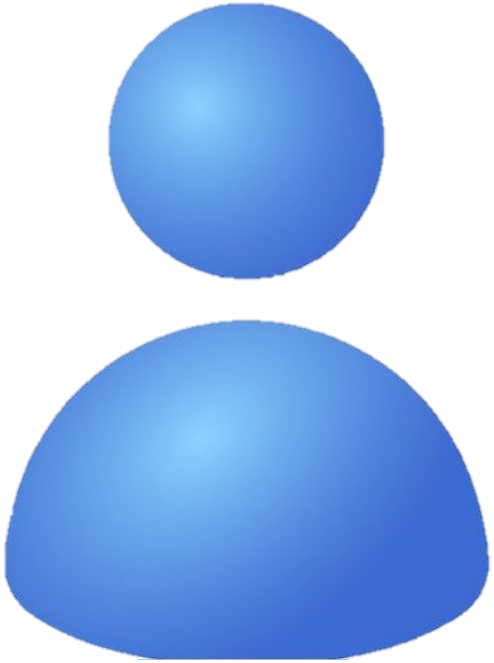
Entusiasta de Windows



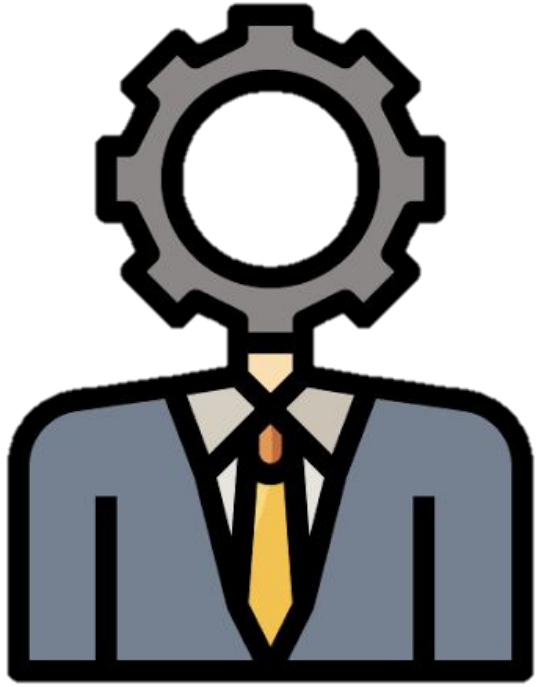


Explotando la lógica de Active Directory: Una revisión de CVEs críticos

LO MÁS SATISFACTORIO (o no ...)







Usuario Estándar

Administrador de Dominio

ATAQUES DE ACTIVE DIRECTORY



ASREPROASTING

KERBEROASTING

ERRORES DE CONFIGURACIÓN



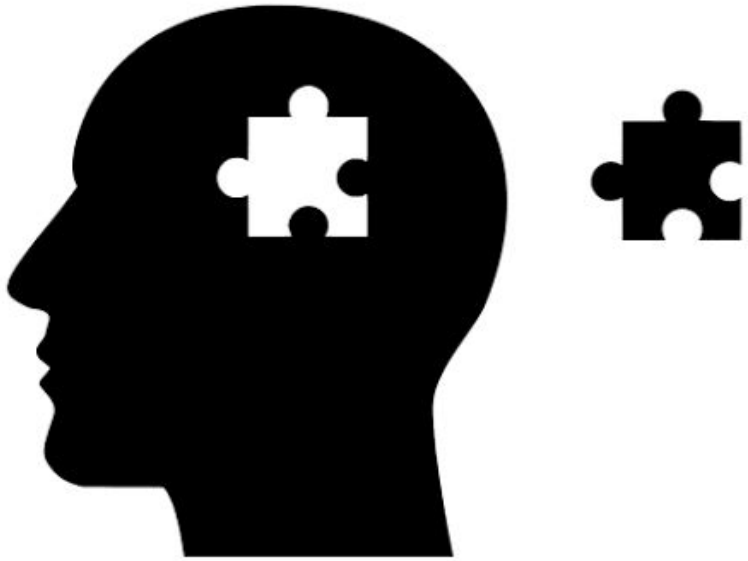
SILVER TICKET

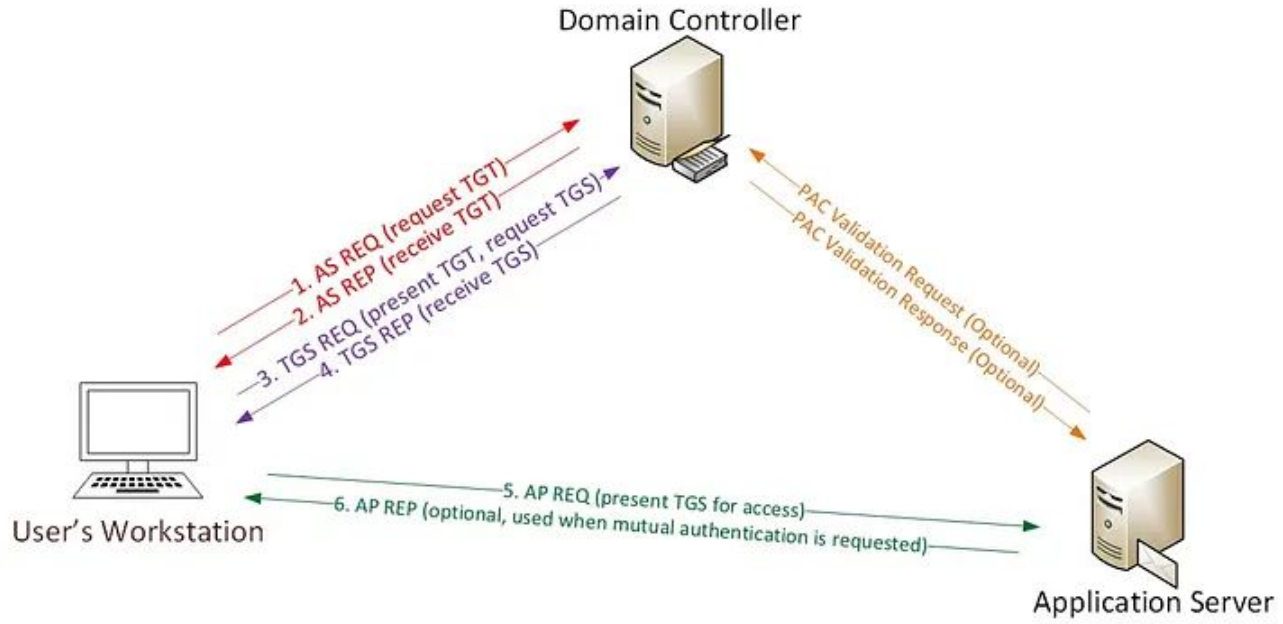
GOLDEN TICKET

POST EXPLOTACIÓN DE SERVIDORES

ATAQUES DE ACTIVE DIRECTORY

ERRORES DE LÓGICA EN EL PROPIO DISEÑO DE ACTIVE DIRECTORY





El mapa de hoy: 3 actos, 0 exploits

ACTO 1

NO-PAC

La credencial sin QR... y el staff que completa el “$”

CVE-2021-42278 + CVE-2021-42287

ACTO 2

RESETNIGHTMARE

Re-imprimir la credencial de otro: el cambio de contraseña que no pregunta quién eres

kadmin/changepw

ACTO 3

KERBERLOSS

El nombre invisible: Unicode + alias de SPN

SPN hijacking

Tres errores de lógica de diseño. Cero exploits.


NO-PAC

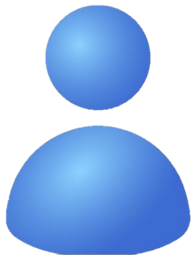
NoPac

Escalada de privilegios a Administrador de Dominio para cualquier usuario común de la red

CVE-2021-42278

CVE-2021-42287

KERBEROS REDUCIDO



Solicitud de identificador

ENTREGA DE TGT

Solicitud de acceso a servicio + TGT

ENTREGA DE ST

KDC

ST de SERV 1	→	SERV 1
ST de SERV 2	→	SERV 2

KERBEROS: EL TGT ES TU IDENTIFICADOR



TGT (Ticket Granting Ticket)

Cname:HUGO@EKOPARTY.LOCAL
Sname: KRBTGT/EKOPARTY.LOCAL
Timestamp: Emitido 14:30
Flags: PRE-AUTHENT

PAC

Logon Domain: EKOPARTY
Usuario: HUGO
Grupos: Asistentes

KERBEROS: EL TGT ES TU IDENTIFICADOR



TGT (Ticket Granting Ticket)

Cname:HUGO@EKOPARTY.LOCAL
Sname: KRBTGT/EKOPARTY.LOCAL
Timestamp: Emitido 14:30
Flags: PRE-AUTHENT

PAC
Logon Domain: EKOPARTY
Usuario: HUGO
Grupos: Asistentes

KERBEROS: EL ST ES PARA ACCEDER A LOS RECURSOS

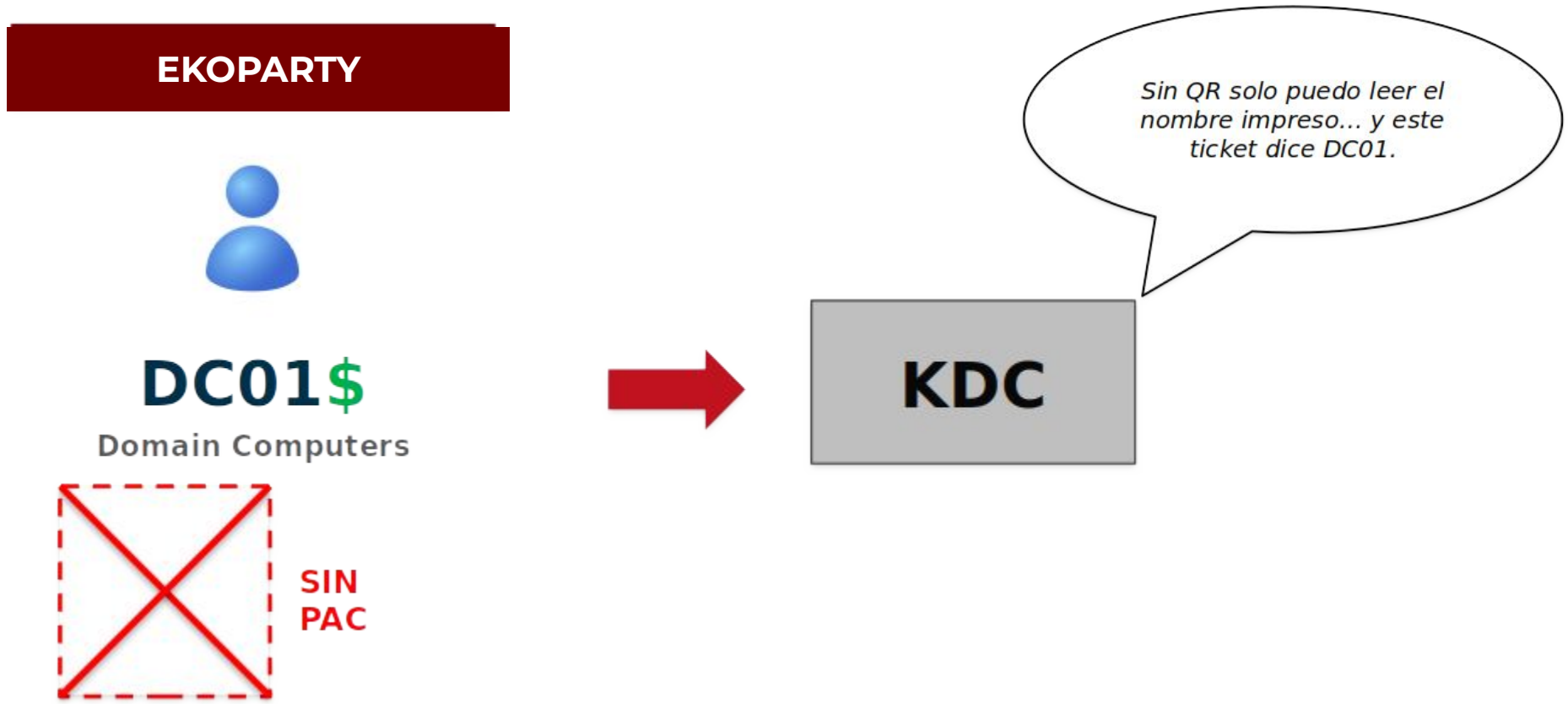


WORKSHOP DE IA

WORKSHOP DE BUG BOUNTY

PONENTE EN MAIN TRACK

PROBLEMA 1: TGTs que se pueden pedir sin PAC



Sin PAC, la única identidad del ticket es el nombre impreso (cname). Y ese nombre lo eliges tú al crear la cuenta.

PROBLEMA 2: Suposición del KDC

Lo normal: En Active Directory, las cuentas de computadora deben de terminar con el símbolo $.

```
PS C:\Users\Administrator> Get-ADComputer DCWS25


DistinguishedName : CN=DCWS25,OU=Domain Controllers,DC=hugocorp,DC=local
DNSHostName       : DCWS25.hugocorp.local
Enabled           : True
Name              : DCWS25
ObjectClass       : computer
ObjectGUID        : ae5355ff-b8ad-40fd-add2-f176e0ddc91e
SamAccountName    : DCWS25$
SID               : S-1-5-21-1335076074-2298715889-390033331-1000
UserPrincipalName :
```

HOST01$

SRV01$

DC01$

PROBLEMA 2: Suposición del KDC

Usuarios, scripts y admins escriben DC01 cuando la cuenta real es DC01$.



El KDC decidió ser servicial: "Si no encuentro el nombre, quizá te olvidaste de un $".

Problema 3: Bypass en el SAMAccountName

No existía una validación de ese control :p por lo que un usuario puede renombrar el atributo de la cuenta de computadora.



Problema 3: Bypass en el SAMAccountName

No existía una validación de ese control :p por lo que un usuario puede renombrar el atributo de la cuenta de computadora.



Podemos llamarlo DC01, porque el DC original se llamará DC01$

TENEMOS LO SIGUIENTE:

CVE-2021-42278

PROBLEMA: Bypass en el SAMAccountName

CVE-2021-42287

PROBLEMA: Suposición del KDC (Agrega $)

PROBLEMA: TGTs que se pueden pedir sin PAC.

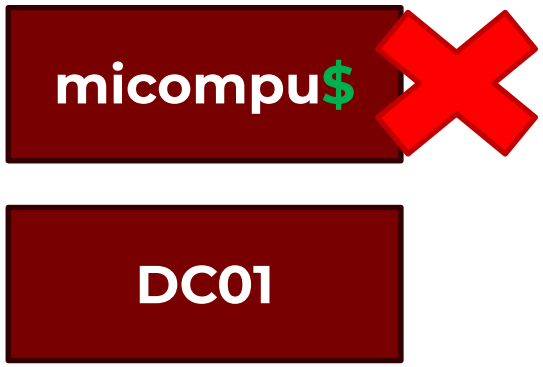
AHORA SÍ: NOPAC!

NoPac

1.







CVE-2021-42278 **PROBLEMA:** Bypass en el SAMAccountName

NoPac

1.



DC01



micompu$

DC01

2.



TGT

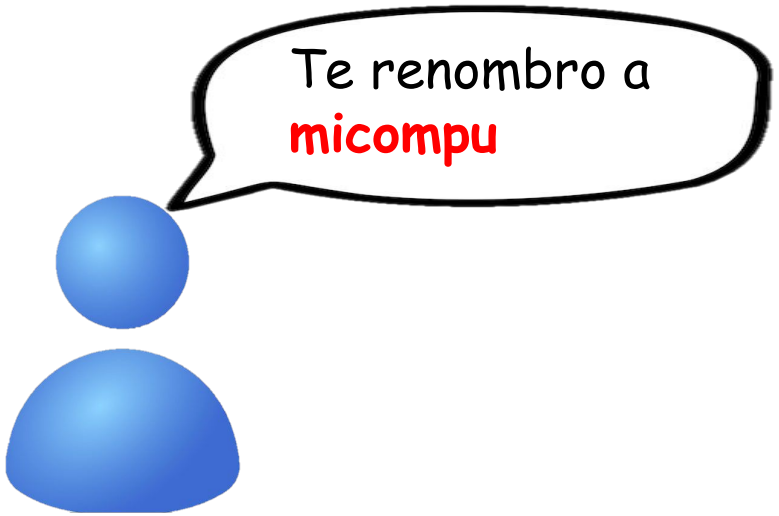
DC01
Sname: krbtgt
Timestamp
Flags

PAC

CVE-2021-42287 **PROBLEMA**: TGTs que se pueden pedir sin PAC.

NoPac

3.





micompu$

DC01

TGT

DC01
Sname: krbtgt
Timestamp
Flags

PAC

NoPac

4.



TGT

DC01
Sname: krbtgt
Timestamp
Flags

PAC

CIFS/DC01

TGS REQ

KDC

NO HAY PAC.
USO EL CNAME

NoPac

TGT

5.

DC01
Sname: krbtgt
Timestamp
Flags

PAC

CIFS/DC01

TGS REQ

KDC

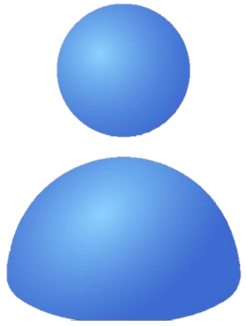
NO HAY PAC.
USO EL CNAME

PAC
DC01

No encuentro “DC01”. Te debes referir a “DC01$”

TGS

6.



DC01
Sname: CIFS/DC01
Timestamp
Flags

PAC
EKOPARTY.LOCAL
DC01$
DOMAIN CONTROLLERS

NoPac

Mitigaciones aplicadas por Microsoft

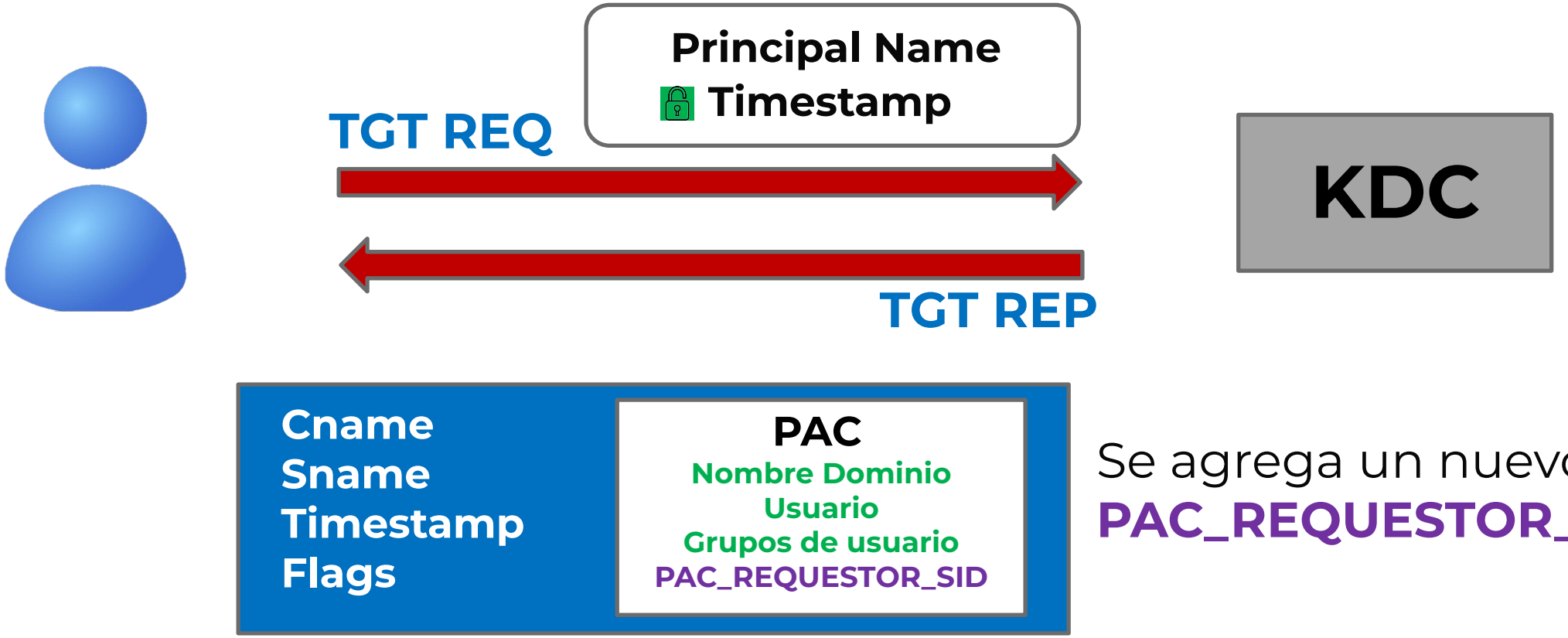
1. **No se puede editar el sAMAccount name por uno que no posea $.**

1. **No se pueden solicitar TGT sin PAC.**

1. **Se agrega un nuevo buffer: PAC_REQUESTOR_SID.**

PARCHES APLICADOS

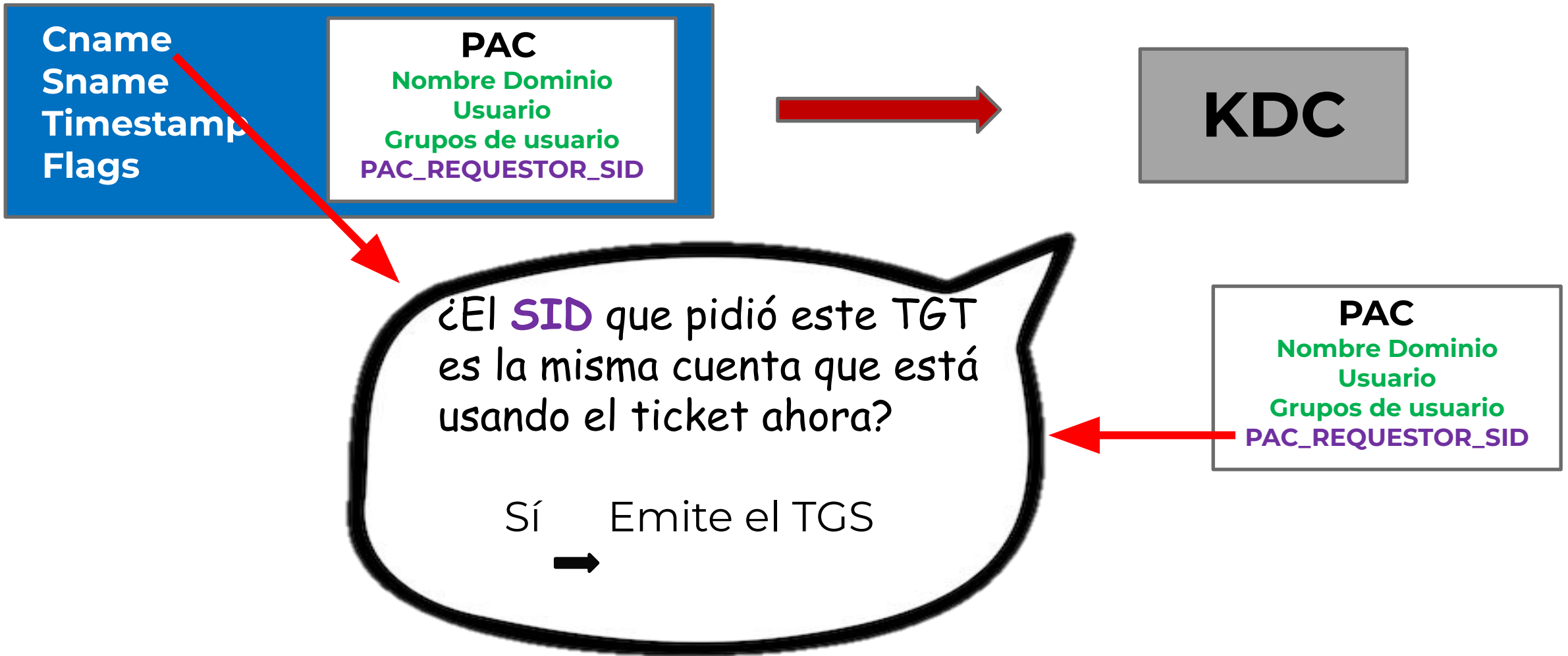
El parche CVE-2021-42287 (KB5008380)



Se agrega un nuevo buffer: **PAC_REQUESTOR_SID**.

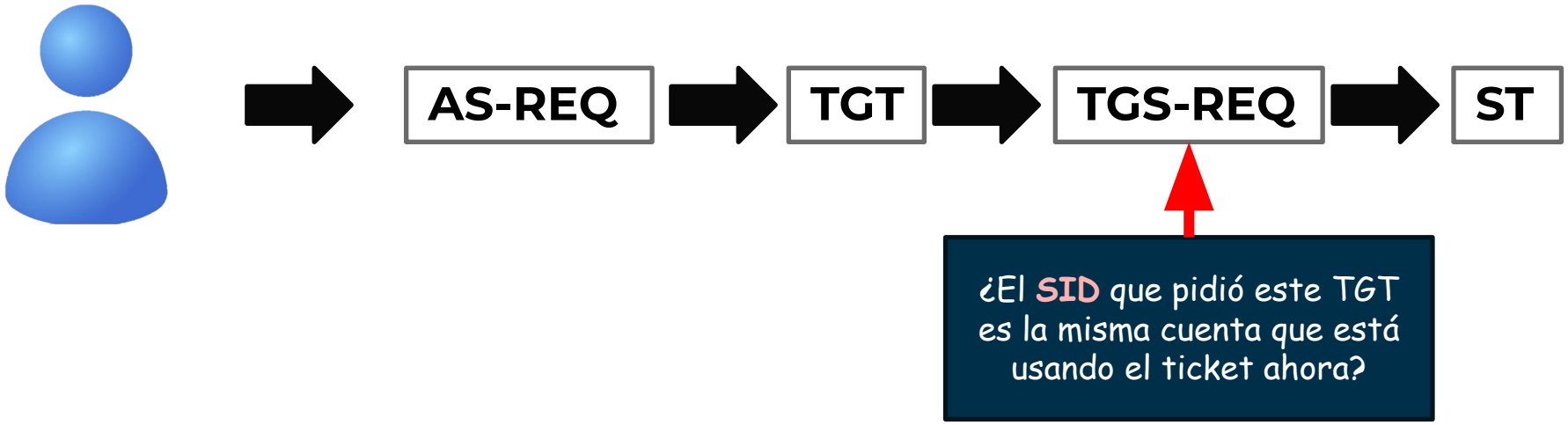
PARCHES APLICADOS

El parche CVE-2021-42287 (KB5008380)



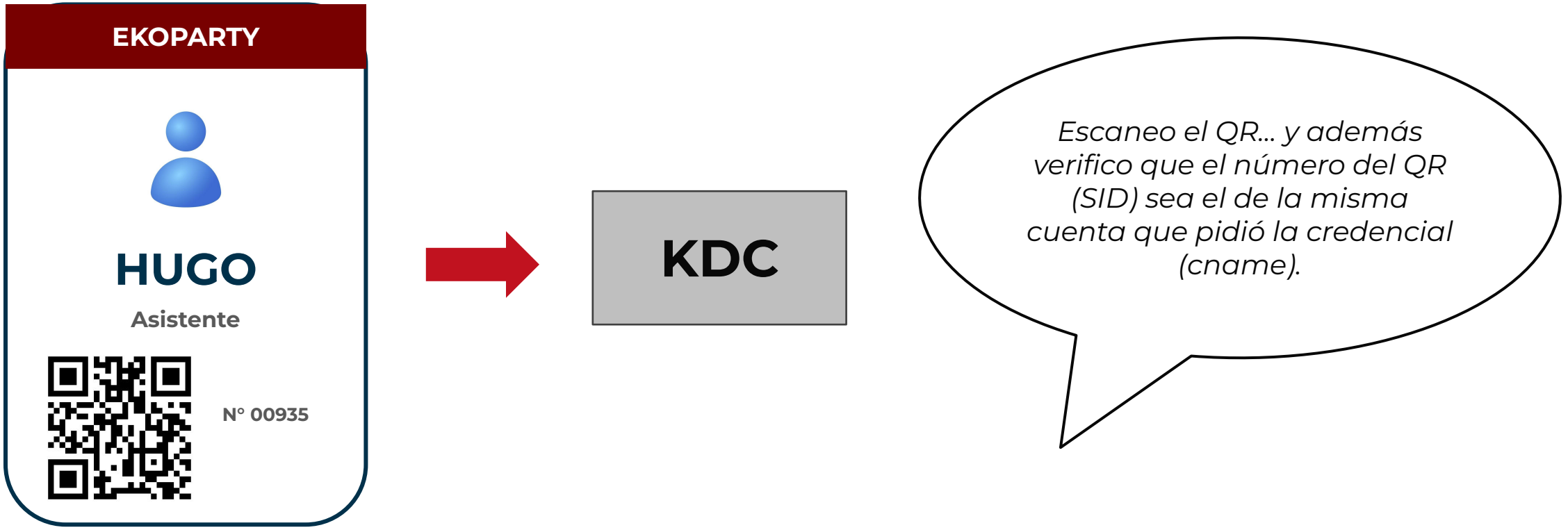
PARCHES APLICADOS

El parche CVE-2021-42287 (KB5008380)



Se agregó una validación extra en la solicitud de Tickets de Servicio.

El parche, en la EKO: el QR también dice quién lo pidió



Antes: el staff solo escaneaba el QR (si había) y confiaba en el nombre impreso.

Ahora (PAC_REQUESTOR_SID): el ticket queda atado al SID de quien lo pidió. Al pedir un TGS, el KDC comprueba que la cuenta que usa el ticket sea la misma que lo solicitó; si no coincide, lo rechaza.



RESETNIGHTMARE

ACTO 2 · El cambio de contraseña que no pregunta quién eres

PARCHES APLICADOS PREVIOS

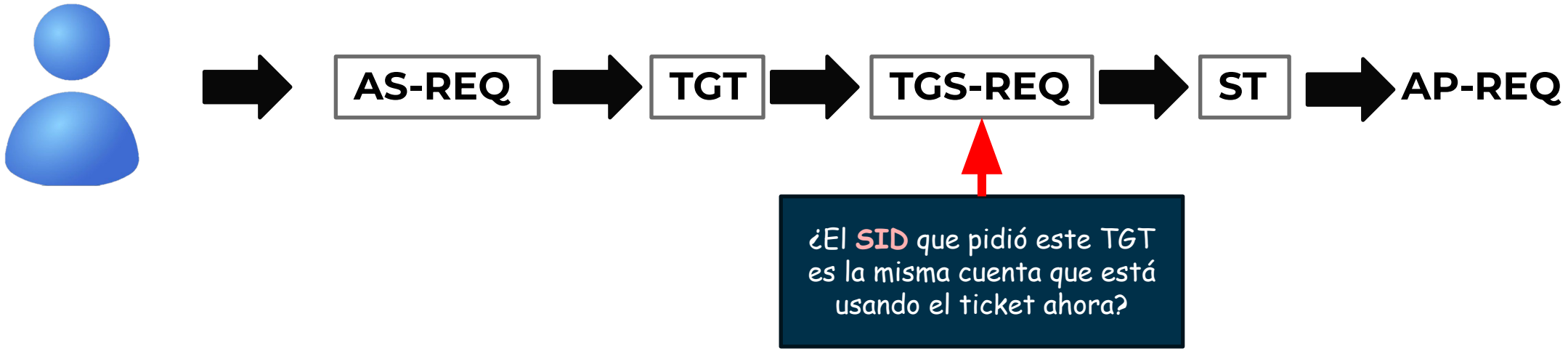
El parche CVE-2021-42287 (KB5008380)

El TGT siempre lleva PAC. **Ya no se puede pedir un TGT sin PAC**.

Se agrega un nuevo buffer: **PAC_REQUESTOR_SID**.

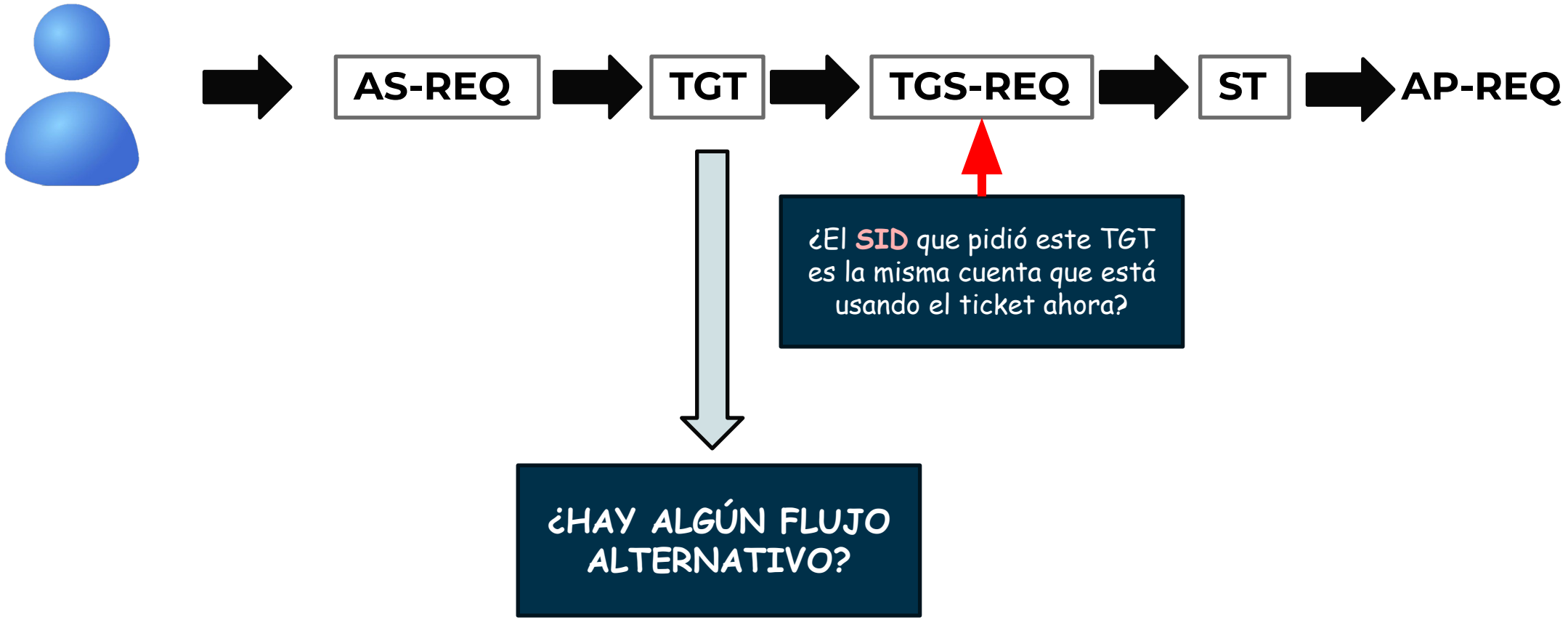
PARCHES APLICADOS

El parche CVE-2021-42287 (KB5008380)



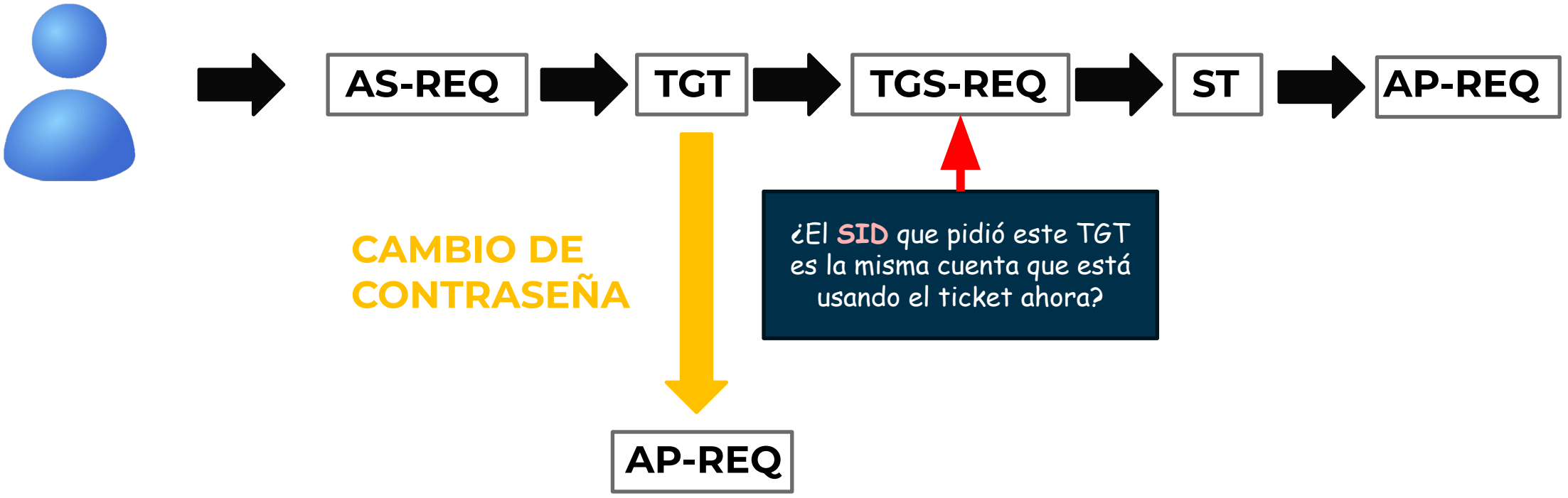
PARCHES APLICADOS

El parche CVE-2021-42287 (KB5008380)

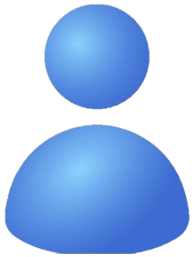


KERBEROS CHANGE PASSWORD

En el cambio de contraseñas por Kerberos, no se utiliza un Service Ticket. Solo se modifica el TGT cambiando su sname.



KERBEROS CHANGE PASSWORD



Cname
Sname: krbtgt/DOMINIO.COM
Timestamp
Flags

PAC
Nombre Dominio
Usuario
Grupos de usuario
PAC_REQUESTOR_SID

Cname
Sname: kadmin/changepw
Timestamp
Flags

PAC
Nombre Dominio
Usuario
Grupos de usuario
PAC_REQUESTOR_SID

KDC

KERBEROS CHANGE PASSWORD

PROBLEMA: Si se obtiene un TGT con denominación para el usuario que querramos, podríamos cambiarle la contraseña ...

Cname: administrator
Sname: kadmin/changepw
Timestamp
Flags

PAC
Nombre Dominio
Usuario
Grupos de usuario
PAC_REQUESTOR_SID

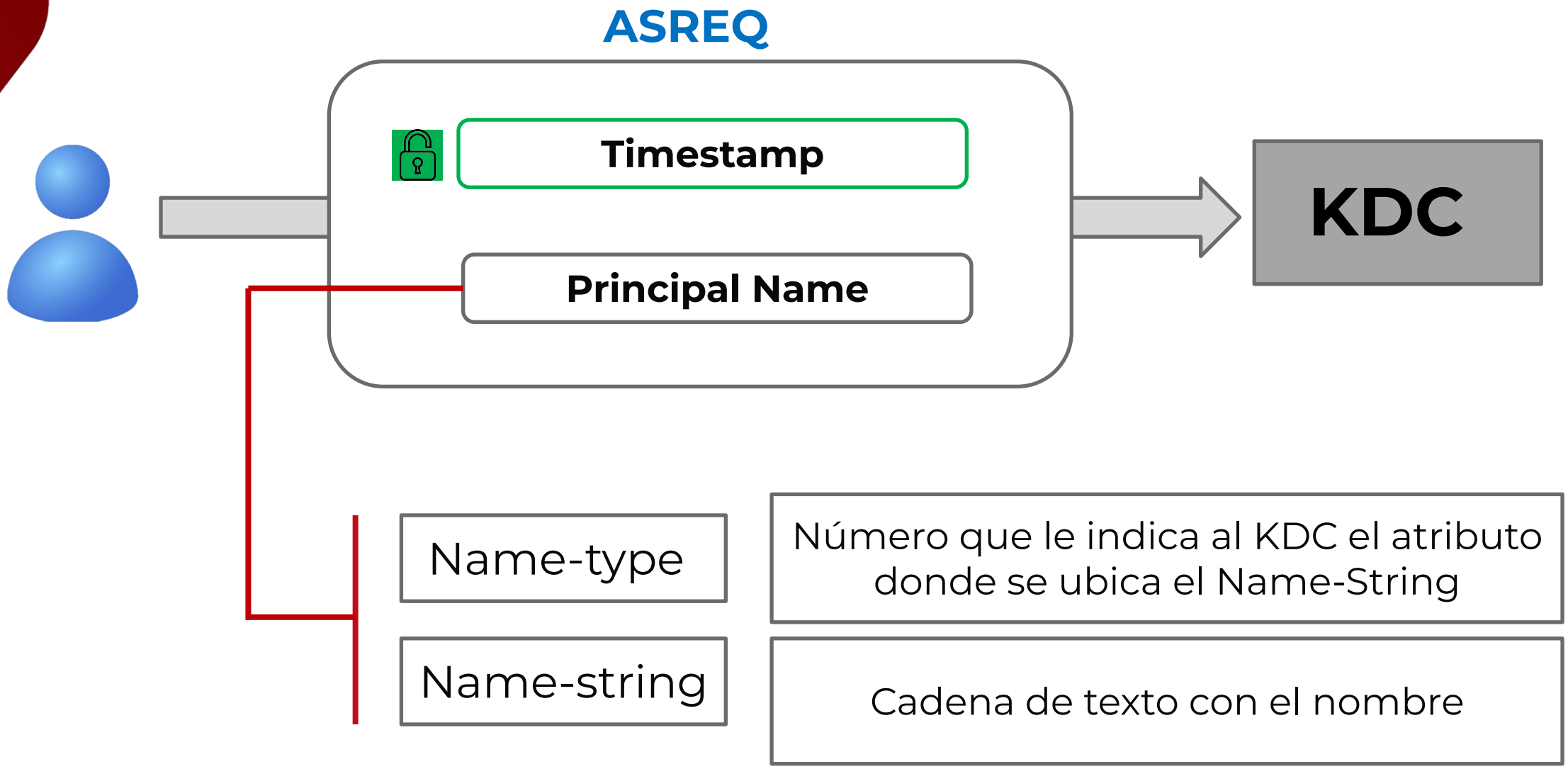
NT-PRINCIPAL vs NT-ENTERPRISE

NT-PRINCIPAL (1)	NT-ENTERPRISE (10)
Te busca por tu nombre común.	Te busca por tu “email” registrado.
sAMAccountName	**UPN**
→ HUGO	→ hugo@ekoparty.local

El name-type le dice al KDC en qué atributo buscar tu nombre.

Y si alguien con GenericWrite cambia tu “email registrado” (UPN) por el del administrados… **eso es lo que viene.**

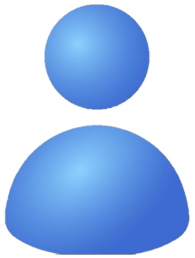
SOLICITUD DE TGT

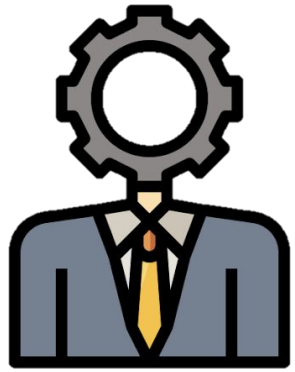


RESETNIGHTMARE ATTACK



Generic Write



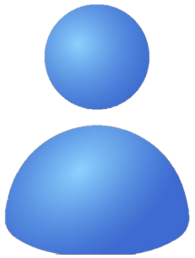


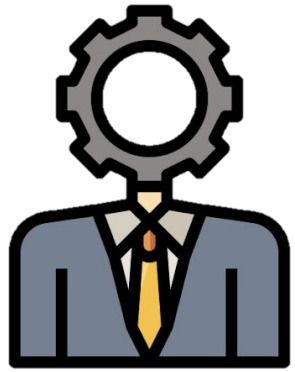
sAMAccountName: user2
UPN: user2@dominio.local

sAMAccountName: admin
UPN: admin@dominio.local

RESETNIGHTMARE ATTACK







sAMAccountName: user2
UPN: admin

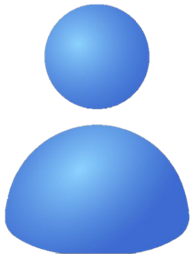
sAMAccountName: admin
UPN: admin@dominio.local

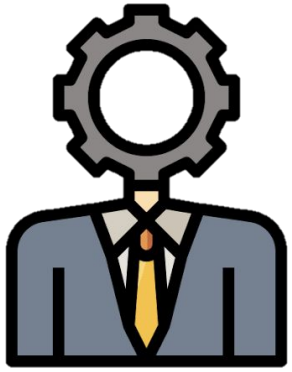
Verificación de unicidad

RESETNIGHTMARE ATTACK



Generic Write





sAMAccountName: user2
UPN: admin

sAMAccountName: admin
UPN: admin@dominio.local

ASREQ



Timestamp

admin

TGT

admin
krbtgt/dominio.local
Timestamp
flags

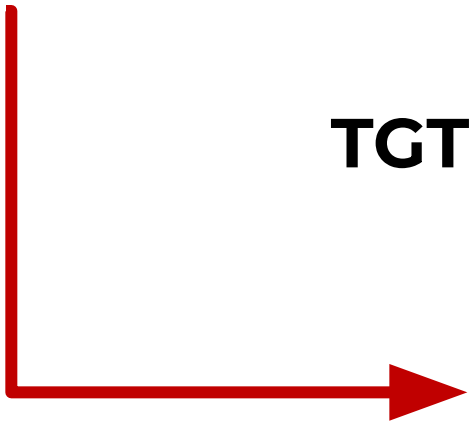
PAC
Nombre Dominio
admin
Grupos de usuario
User2 SID

RESETNIGHTMARE ATTACK

TGT

admin
krbtgt/dominio.local
Timestamp
flags

PAC
Nombre Dominio
admin
Grupos de usuario
User2 SID



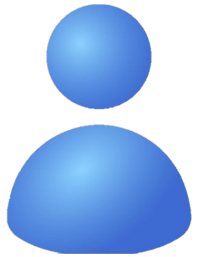
TGT MODIFICADO - Cambio de contraseña

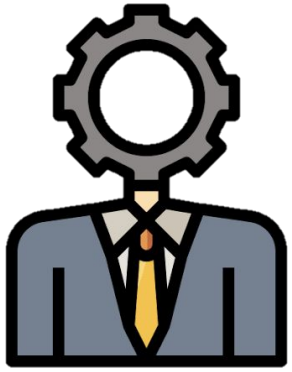
admin
kadmin/changepw
Timestamp
flags

PAC
Nombre Dominio
admin
Grupos de usuario
User2 SID

RESETNIGHTMARE ATTACK







sAMAccountName: user2
UPN: **user2**@dominio.local

sAMAccountName: admin
UPN: admin@dominio.local

TGT MODIFICADO - Cambio de contraseña

admin
kadmin/changepw
Timestamp
flags

PAC
Nombre Dominio
admin
Grupos de usuario
User2 SID

KDC

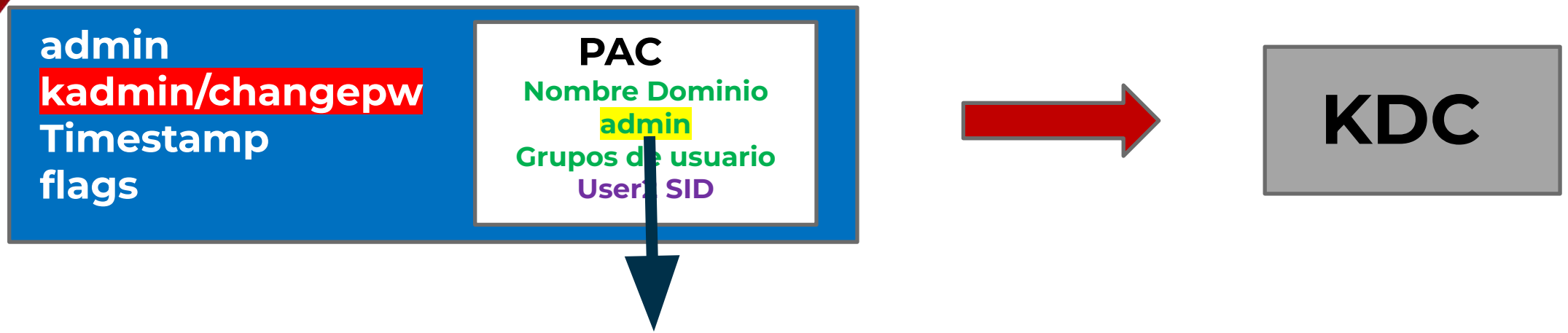
RESETNIGHTMARE ATTACK

TGT MODIFICADO - Cambio de contraseña



RESETNIGHTMARE ATTACK

TGT MODIFICADO - Cambio de contraseña



KDC busca usuario admin en el dominio

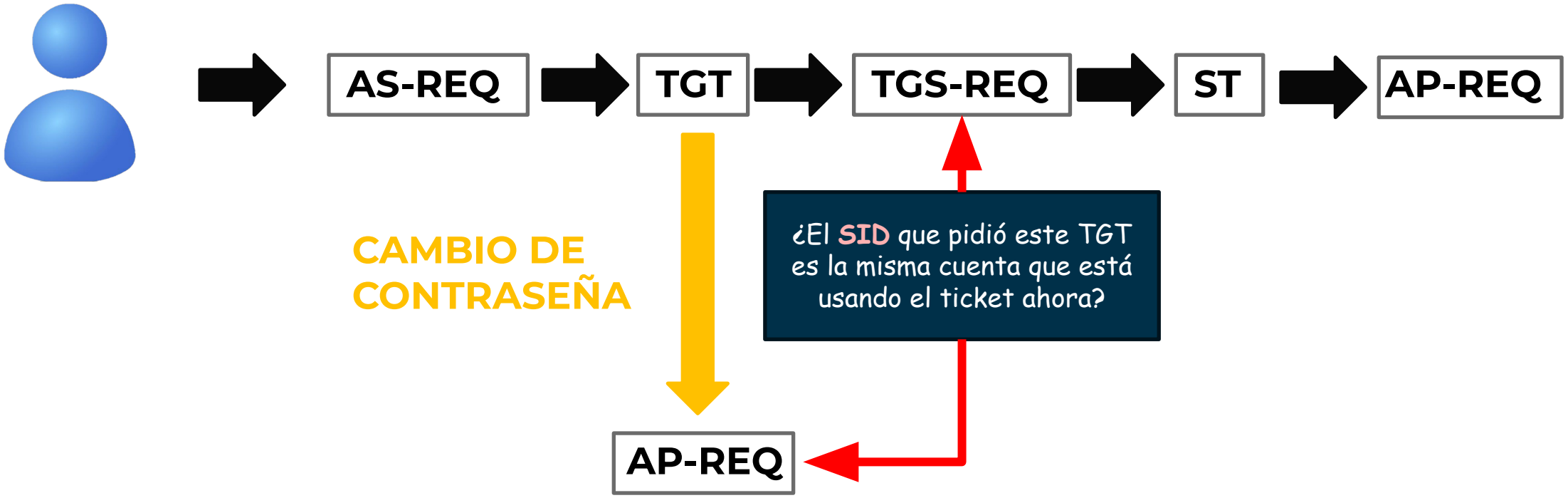
Usuario admin es Domain Admin

Obtenemos nueva contraseña para admin

RESET NIGHTMARE

Mitigaciones aplicadas por Microsoft

En el procesador del servicio kadmin/changepw (función KdcChangePassword), se insertó una validación antes de autorizar el cambio:





KERBERLOSS

ACTO 3 · El nombre invisible

¿Estas credenciales son iguales?



A



B

Levanta la mano: SÍ o NO

Respuesta: NO, son Diferentes

A: SERVERB$

B: SERVERB[U+200C]$

La B lleva un zero-width non-joiner: invisible para ti, invisible en ADUC y no filtrable por LDAP.

Active Directory las acepta como dos objetos distintos… aunque se vean idénticos.

Y así empieza KerberLoss.

Uso de unicode

No se pueden crear cuentas con el mismo nombre

```
PS C:\Users\Administrator> New-ADUser -Name 'UserUnicode'
PS C:\Users\Administrator> New-ADUser -Name 'UserUnicode'
New-ADUser : The specified account already exists
At line:1 char:1
+ New-ADUser -Name 'UserUnicode'
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ResourceExists: (CN=UserUni
   readyExistsException
    + FullyQualifiedErrorId : ActiveDirectoryServer:1316,
```

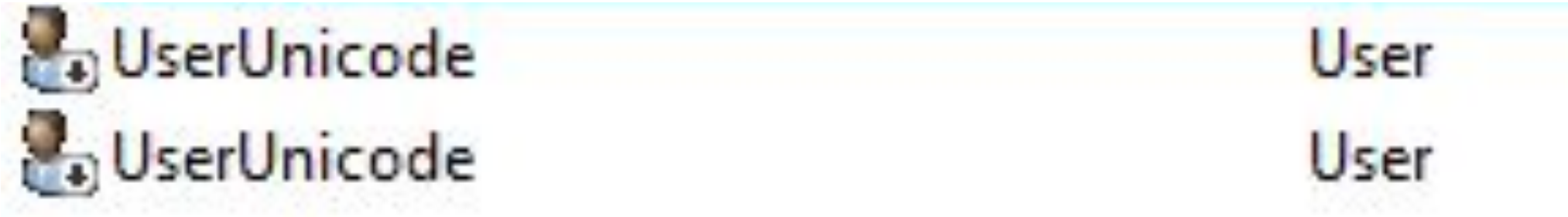
Uso de unicode

Pero se crea exitosamente un usuario con un caracter unicode “0x200B”

```
PS C:\Users\Administrator> New-ADUser -Name ("User"+[char]::ConvertFromUtf32([int]"0x200B")+"Unicode") -PassThru


DistinguishedName : CN=User Unicode,CN=Users,DC=hugocorp,DC=local
Enabled           : False
GivenName         :
Name              : User Unicode
ObjectClass       : user
ObjectGUID        : 7debff61-6cab-48a6-9494-f40bb9d59dee
SamAccountName    : User Unicode
SID               : S-1-5-21-48350778-1559360016-1500837754-1607
Surname           :
UserPrincipalName :
```

Se observa la vista del usuario creado en ADUC (Interfaz Gráfica de AD)



Uso de unicode

Se iteró sobre otros caracteres Unicode no imprimibles:

FUNCIONAN

U+0085, U+00A0, U+00AD, U+1680, U+2000, U+2001, U+2004, U+2005, U+2006, U+2007, U+2008, U+2009, U+200A, U+200B, U+2028, U+2029, U+2800, U+3164, U+115F, U+17B4, U+17B5, U+E0001, U+E0020, U+E0041

ERROR: DUPLICADOS

U+2002, U+2003, U+200C, U+200D, U+200E, U+200F, U+202A, U+202B, U+202C, U+202D, U+202E, U+202F, U+205F, U+2060, U+2061, U+2062, U+2063, U+2064, U+2066, U+2067, U+2068, U+2069, U+3000, U+034F, U+061C, U+1160, U+180B, U+180C, U+180D, U+180E, U+FEFF, U+FFA0, U+FFF9

ERROR: NO DEJA

U+0009, U+000A, U+000B, U+000C, U+000D

Los caracteres dentro de “**DUPLICADOS**” probablemente no sean procesados

Uso de unicode

Intento de creación con otro caracter: Ahora el 0x200C

```
PS C:\Users\Administrator> New-ADUser -Name ("User"+[char]::ConvertFromUtf32([int]"0x200C")+"Unicode")
New-ADUser : The specified account already exists
At line:1 char:1
+ New-ADUser -Name ("User"+[char]::ConvertFromUtf32([int]"0x200C")+"Uni ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ResourceExists: (CN=User Unicode...gocorp,DC=local:String) [New-ADUser],
    + FullyQualifiedErrorId : ActiveDirectoryServer:1316,Microsoft.ActiveDirectory.Management.Commands.
```

El caracter es ignorado por los filtros LDAP

LDAP(ekoparty)=LDAP(eko[0x200C]party)

```
PS C:\Users\Administrator> $usuarioConCaracterInvisible="User"+[char]::ConvertFromUtf32([int]"0x200C")+"Unicode"
PS C:\Users\Administrator> $usuarioConCaracterInvisible | Set-Clipboard
PS C:\Users\Administrator> Get-ADObject -LDAPFilter "samaccountname=User?Unicode"

DistinguishedName                              Name        ObjectClass ObjectGUID
-----------------                              ----        ----------- ----------
CN=UserUnicode,CN=Users,DC=hugocorp,DC=local UserUnicode user        c0a63836-5623-4e4a-a9f6-149df6b4d907
```

Uso de unicode

Buscamos todos los objetos que contengan “0x200C”

```
PS C:\> $filter="samaccountname=*{0}*" -f [char]::ConvertFromUtf32([int]"0x200C")
PS C:\> (Get-ADObject -LDAPFilter $filter).count
61
```

- Algunos caracteres no son parseados por Active Directory y son aparentemente invisibles

- Algunos de estos caracteres no son filtrables por LDAP

Uso de unicode

Existe un potencial bypass de unicidad

Lo que realmente es:

- **User[0x200C]Unicode**
- **User[0x200D]Unicode**
- **Us[0x202A]erUnicode**
- **UserUni[0x200F]code**

Lo que lee el AD:

UserUnicode

SPN

Service Principal Names: Nombre con el que se identifican a los servicios.

serviceclass/host:portt

TERMSRV: Escritorio Remoto
CIFS: Recursos Compartidos
HTTP: Servicios Web

Un host puede proporcionar servicios de varias clases.

Alias SPN

Cuando se añade una computadora al dominio, se le agrega un SPN de clase HOST.



micomputer

HOST/micomputer

- HTTP
- CIFS
- TERMSRV

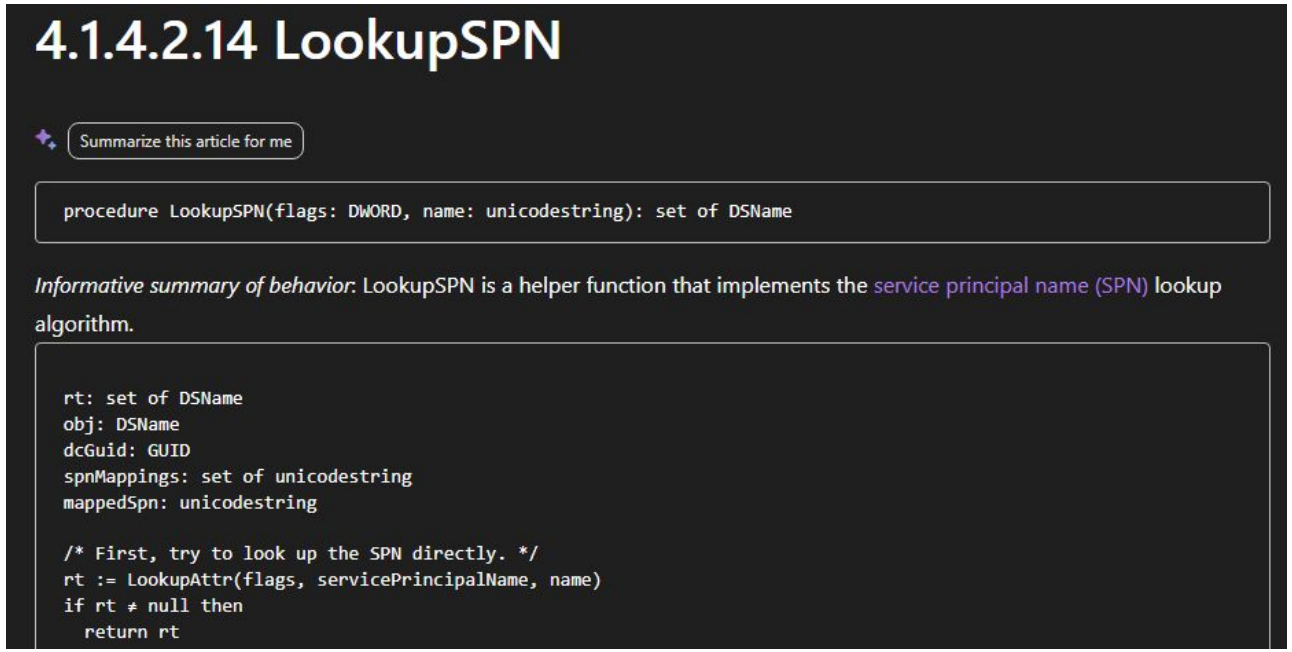
Domain Controllers mapean SPNs comunes a HOST SPN

Alias SPN

Cómo es la búsqueda de SPNs?

Mirar el SPN directamente

Obtener SPN mappings value. (ALIAS)



4.1.4.2.14 LookupSPN

Summarize this article for me

```
procedure LookupSPN(flags: DWORD, name: unicodestring): set of DSName
```

Informative summary of behavior: LookupSPN is a helper function that implements the service principal name (SPN) lookup algorithm.

```
rt: set of DSName
obj: DSName
dcGuid: GUID
spnMappings: set of unicodestring
mappedSpn: unicodestring

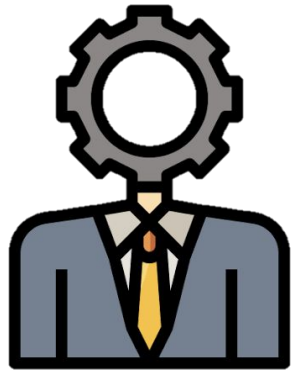
/* First, try to look up the SPN directly. */
rt := LookupAttr(flags, servicePrincipalName, name)
if rt ≠ null then
  return rt
```

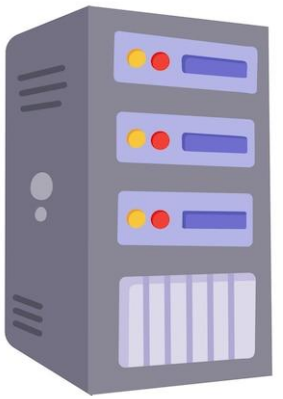
KERBERLOSS ATTACK

LO NORMAL









sAMAccountName: ServerC$
SPNs:

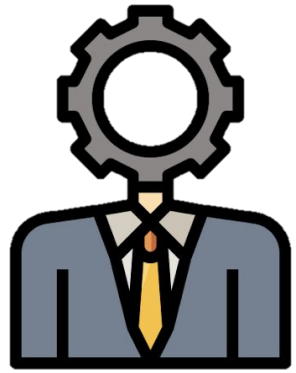
sAMAccountName: ServerB$
SPNs: HOST/ServerB

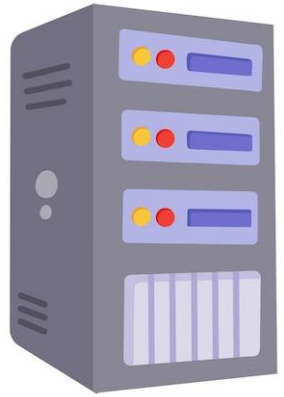
KERBERLOSS ATTACK

LO NORMAL









sAMAccountName: ServerC$ **sAMAccountName**: ServerB$

SPNs: CIFS/ServerB **SPNs**: HOST/ServerB

Verificación de unicidad

CIFS → Alias de HOST → HOST ya está registrado

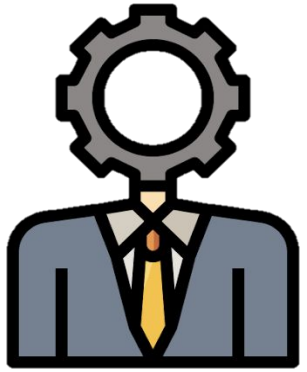
RECHAZADO

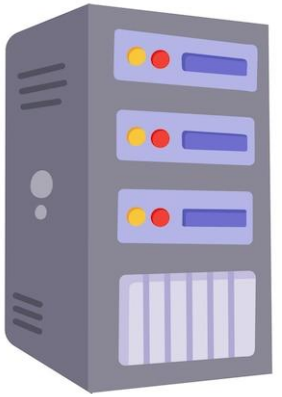
KERBERLOSS ATTACK

Pero si usamos unicode ...









sAMAccountName: ServerC$
SPNs: CIFS/Server<U+200C>B

sAMAccountName: ServerB$
SPNs: HOST/ServerB

Verificación de unicidad

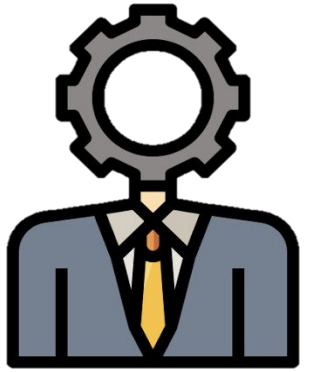
ACEPTADO

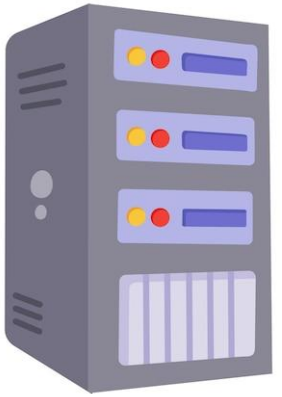
KERBERLOSS ATTACK

Pero si usamos unicode ...









sAMAccountName: ServerC$
SPNs: CIFS/Server<U+200C>B

sAMAccountName: ServerB$
SPNs: HOST/ServerB

SPNs: CIFS/ServerB

KDC

Mapeo Directo
Mapeo Alias

sAMAccountName

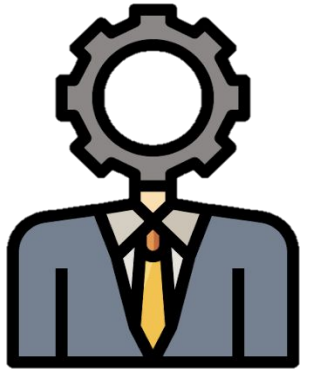
ServerC$
ServerB$

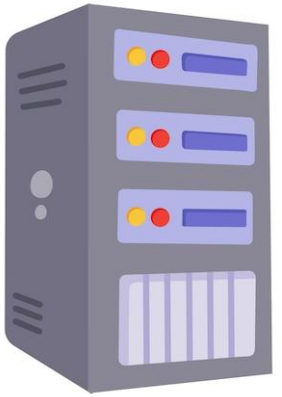
KERBERLOSS ATTACK

Pero si usamos unicode ...









sAMAccountName: ServerC$
SPNs: CIFS/Server<U+200C>B

sAMAccountName: ServerB$
SPNs: HOST/ServerB

SPNs: CIFS/ServerB

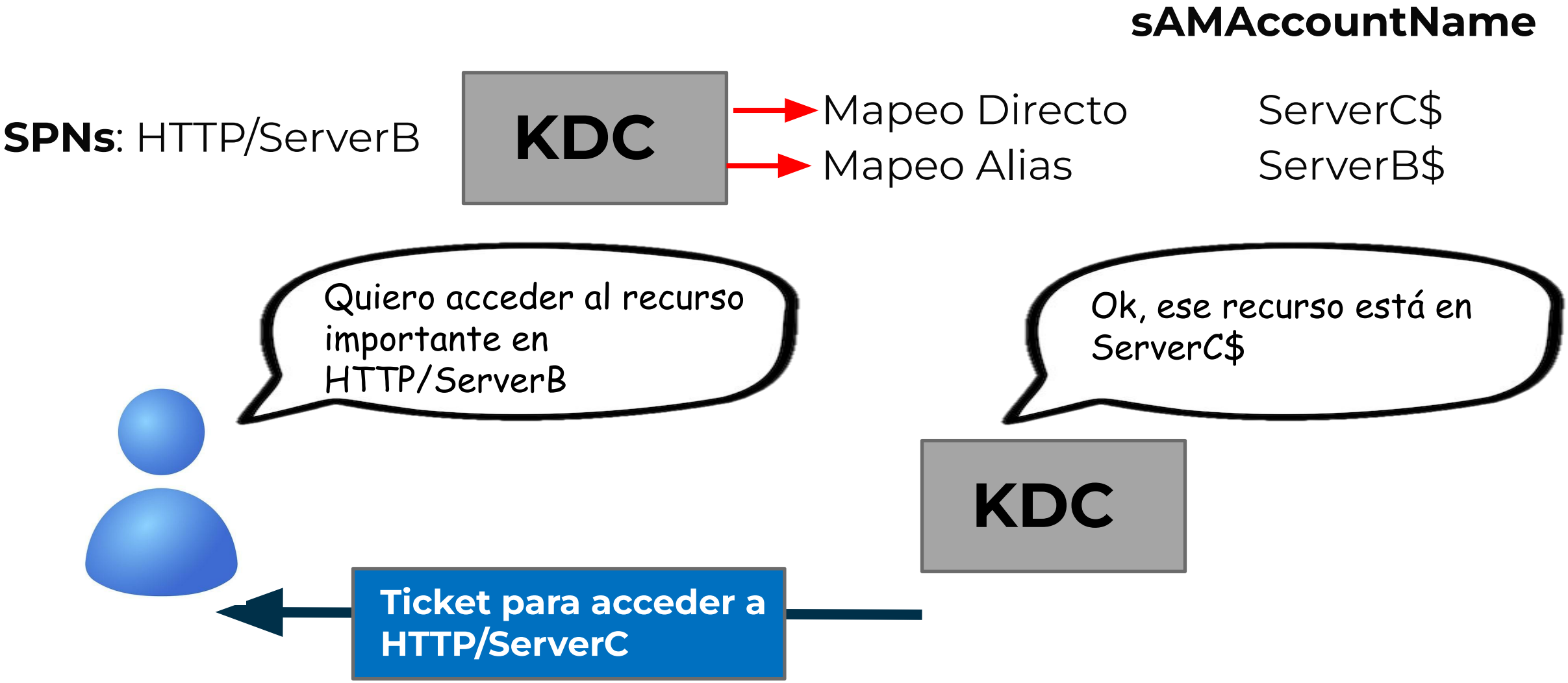
KDC

Mapeo Directo
Mapeo Alias

sAMAccountName

ServerC$
ServerB$

KERBERLOSS ATTACK



KERBERLOSS ATTACK

sAMAccountName

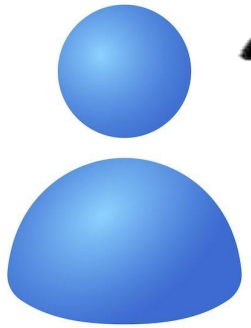
SPNs: HTTP/ServerB

KDC

Mapeo Directo → ServerC$

Mapeo Alias → ServerB$

Quiero acceder al recurso importante en HTTP/ServerB



Ticket para acceder a HTTP/ServerC

No entiendo



ServerB


BAD SUCCESSOR

¿Qué es una dMSA?

Nueva en Windows Server 2025: la evolución de las cuentas de servicio administradas (gMSA).

Permite migrar una cuenta de servicio clásica a dMSA sin downtime.

Durante la migración, la dMSA **hereda los permisos y grupos** de la cuenta original: el KDC se los otorga.

Le dices al staff que el ponente del main track te cedió su credencial...

y el staff te da sus accesos sin preguntarle a él.

Ese mecanismo de herencia —pensado para migraciones legítimas— es el que abusa BadSuccessor.

EL ATAQUE: heredar la identidad de otro

1. Prerrequisitos mínimos: escritura sobre una OU (crear dMSAs) + un solo DC con Windows Server 2025 en el dominio.
2. El atacante crea una dMSA y edita dos atributos: msDS-ManagedAccountPrecededByLink → la víctima (p. ej. Administrator) y msDS-DelegatedMSAState = 2 (“migración completada”).
3. Autentica con la dMSA: el KDC emite tickets con los grupos de la víctima.
4. Resultado: Domain Admin sin tocar la contraseña ni la cuenta de la víctima.

BadSuccessor: ¿qué nos llevamos?

- **Nov 2024: Windows Server 2025 sale a producción, con dMSA.**
- **May 2025: BadSuccessor: el feature nuevo ya es un camino a Domain Admin.**
- **Ago 2025: Microsoft parchea.**
- **2026: Investigadores publican dMSA Ouroboros: otra técnica sobre el mismo flujo.**

CONCLUSIONES

NoPac: Abuso de funcionalidades heredadas (TGT sin PAC)

ResetNightmare: Abuso de parches incompletos.

KerberLoss: Abuso de caracteres invisibles no filtrados

BadSuccessor: Nuevas tecnologías, nuevas amenazas.

No fueron errores de código: fueron decisiones de diseño “serviciales”. La lógica también se explota.

Referencias

Semperis - Identity Crisis (NoPac / ResetNightmare):
https://www.semperis.com/es/blog/identity-crisis-novel-vulnerabilities-leading-to-kerberos-downgrade-dos-and-full-domain-takeover/

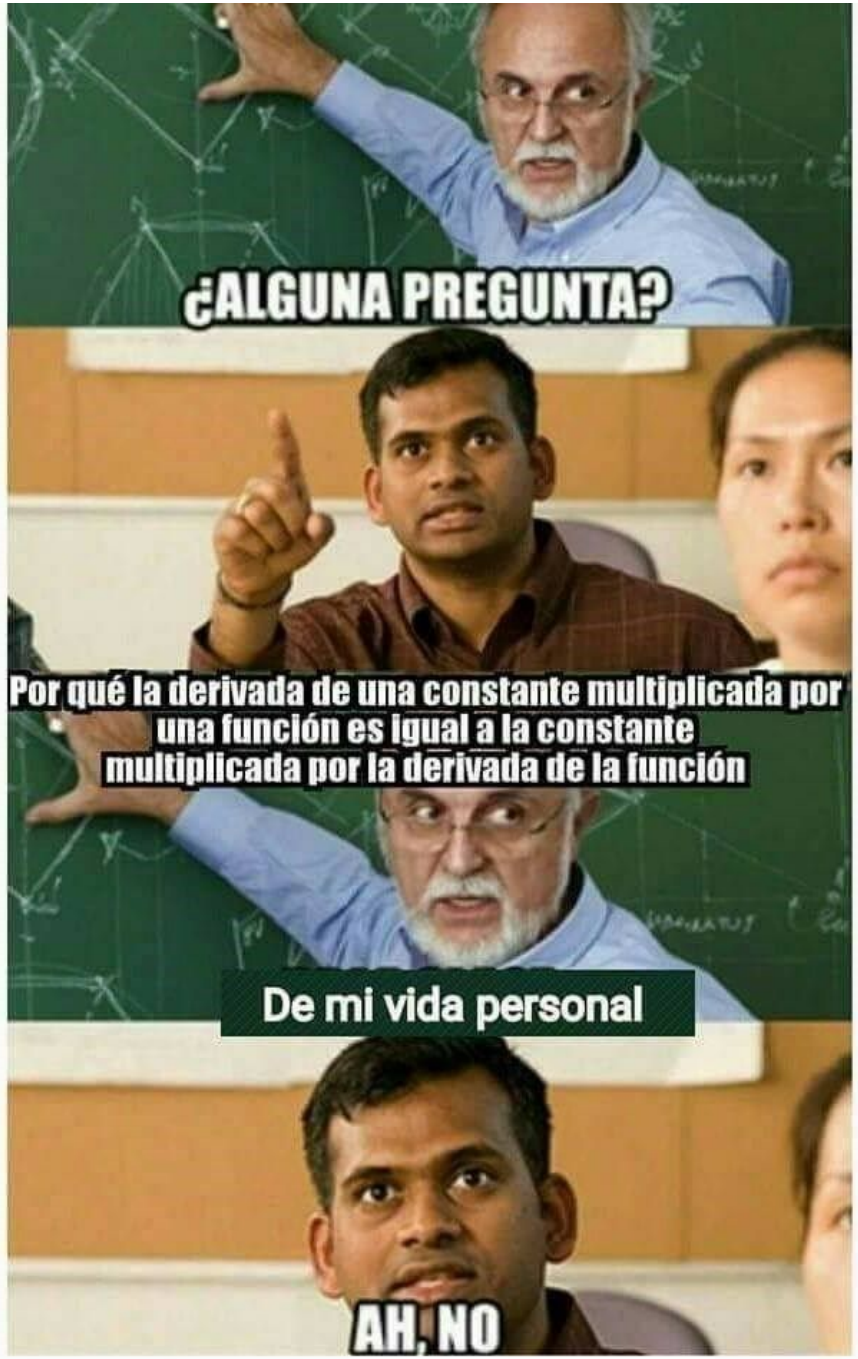
Microsoft Learn - Configuración de SPNs:
https://learn.microsoft.com/es-es/windows-server/identity/ad-ds/manage/how-to-configure-spn

adsecurity.org - Kerberos: https://adsecurity.org/?page_id=183

Infosec Writeups - Introduction to Kerberos:
https://infosecwriteups.com/introduction-to-kerberos-39a1922ec5ac

Akamai - BadSuccessor:
https://www.akamai.com/es/blog/security-research/abusing-dmsa-for-privilege-escalation-in-active-direc

Microsoft - LookupSPN:
https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-drsr/0ad5ee99-bfbe-4520-98f0-4418b761d680


¿ALGUNA PREGUNTA?
Por qué la derivada de una constante multiplicada por una función es igual a la constante multiplicada por la derivada de la función
De mi vida personal
AH, NO

¿PREGUNTAS?

GRACIAS